By Maha Rana

CS627 Finalterm subjective Solved

Short Questions

1. **When Nmap is uncertain about port state, it may provide two possible options in its report. Name those options?**
    - **Open | filtered** (the port is either open or filtered)
    - **Closed | filtered** (the port is either closed or filtered)

2. **Purpose of SSH?**
    - SSH (**Secure Shell**) is a cryptographic network protocol used for secure communication over an unsecured network. It provides secure access to remote computers, encrypted data transfer, and secure authentication.

3. **"Coordination function" in Wireless LAN?**
    - **Coordination function** in WLAN refers to the **method of controlling access to the wireless medium**. It ensures that multiple devices communicate efficiently without collisions. IEEE 802.11 defines two coordination functions:

- **DCF (Distributed Coordination Function):** Uses CSMA/CA (Carrier Sense Multiple Access with Collision Avoidance).
- **PCF (Point Coordination Function):** Uses a centralized approach with polling.

4. **Mention the name of the security standard specifically designed to ensure that all components that accept, process, store, and transmit credit card information maintain a secure environment?**
    - **PCI DSS (Payment Card Industry Data Security Standard)**

5. **Role of access control in operating system security and example?**
    - **Access control** ensures that only authorized users or processes can access specific system resources, preventing unauthorized access and security breaches.
    - **Example:**
        - **Discretionary Access Control (DAC):** A file owner sets permissions for other users.
        - **Mandatory Access Control (MAC):** Security levels define who can access classified data.

6. **Define Trojan Horse?**
    - A **Trojan Horse** is a type of **malware** that disguises itself as a legitimate program to deceive users. Once executed, it can perform

malicious activities such as stealing data, creating backdoors, or taking control of a system.

Long Questions

1. **Port names in Nmap**
    - Nmap categorizes ports into different states based on their responses:
        - **Open**: Actively accepting connections.
        - **Closed**: No service running on the port, but it is accessible.
        - **Filtered**: Firewalls or filters are blocking the scan.
        - **Unfiltered**: Nmap cannot determine if the port is open or closed.
        - **Open | Filtered**: Nmap cannot differentiate whether the port is open or filtered.
        - **Closed | Filtered**: Nmap cannot determine if the port is closed or filtered.

2. **Five operations of IEEE 802.11**
    - **Association:** A device connects to an access point.
    - **Authentication:** Verifies the identity of a device before allowing communication.
    - **Deauthentication:** Disconnects a device from the network.
    - **Reassociation:** Allows a device to switch between access points.
    - **Disassociation:** Terminates a connection from an access point.

By Maha Rana

3. **Shellcode role in buffer overflow attack**
    - **Shellcode** is a small, malicious piece of code used by attackers in a **buffer overflow attack**.
    - When an attacker overflows a buffer, they **overwrite the return address** of a function to point to their shellcode, allowing them to execute arbitrary commands, often gaining **unauthorized access** to a system.

4. **Security Maintenance Plan Tasks**
    - Regular **patch management** and software updates.
    - **Monitoring** system logs for suspicious activity.
    - Performing **vulnerability scans** and penetration testing.
    - Implementing **backup and disaster recovery** strategies.
    - Updating security policies and **training employees** on cybersecurity best practices.

Short Questions

1. **What is Ransomware?**
    - Ransomware is a type of **malware** that **encrypts a victim's files** and demands a ransom payment to restore access. It can also threaten to leak stolen data if the ransom isn’t paid.
    - **Example:** WannaCry, Petya, and Locky ransomware attacks.

By Maha Rana

2. **How many default ports does Nmap scan?**
    - Nmap scans **1,000 most commonly used TCP ports** by default.

3. **What is SSH, and why do we use it?**
    - **SSH (Secure Shell)** is a cryptographic network protocol used for **secure remote login, encrypted file transfers, and secure command execution** over an unsecured network.
    - **Usage:** Remote server management, encrypted communications, tunneling, and authentication.

4. **Three Payment Card Industry (PCI) Standards?**
    - **PCI DSS (Payment Card Industry Data Security Standard)**
    - **PCI PA-DSS (Payment Application Data Security Standard)**
    - **PCI PTS (PIN Transaction Security)**

5. **Which defense systems are used against Buffer Overflow?**
    - **ASLR (Address Space Layout Randomization)**: Randomizes memory locations to prevent predictable attacks.
    - **DEP (Data Execution Prevention)**: Prevents execution of malicious code in non-executable memory regions.
    - **Stack Canaries**: Special values placed on the stack to detect buffer overflows before code execution.

- **Control Flow Integrity (CFI)**: Ensures program execution follows valid control paths.

6. **Data Hiding Techniques + Real-World Cases?**
   - **Techniques:**
     - **Steganography:** Hiding data in images, audio, or videos (Example: Terrorist groups using image files to hide messages).
     - **Encryption:** Converting data into unreadable format using cryptographic algorithms (Example: End-to-End encrypted messaging apps like WhatsApp).
     - **Obfuscation:** Making code difficult to read and understand (Example: Malware hiding its real functionality).
     - **Covert Channels:** Using network protocols to secretly transmit data (Example: Hiding data inside TCP/IP packets).

- *Level of Understanding*: Grey risks are partially understood, but not fully mitigated.
- *Mitigation*: White risks can be mitigated with standard security measures, while Black and Grey risks require more advanced or customized solutions.

Think of it like:
- White: "We know the problem and have a solution."
- Black: "We don't know the problem yet."
- Grey: "We know there's a problem, but we're not sure how to fully fix it."

Long Questions

1. **What are White, Black, and Grey Risks in OS Security?**
   - **White Risk:** Known and documented security vulnerabilities that can be mitigated using standard security measures (e.g., outdated software with available patches).
   - **Black Risk:** Unknown and unpredictable vulnerabilities that can be exploited without prior knowledge (e.g., zero-day exploits).

White Risk: Known security issues with available fixes (e.g., outdated software with patches).
- *Black Risk*: Unknown security threats with no fixes yet (e.g., zero-day exploits).
- *Grey Risk*: Partially known security issues with incomplete fixes or uncertain impact (e.g., partial patches or misconfigurations).

The main differences are:

- *Known vs. Unknown*: White risks are known and can be fixed, while Black risks are unknown and unpredictable.
- *Level o

- **Grey Risk:** Semi-known vulnerabilities where some aspects are understood but not fully mitigated (e.g., partial security patches, misconfigurations).

- *White Risk*: Known security issues that can be fixed with existing solutions (like updating software).
- *Black Risk*: Unknown security threats that can cause harm without warning (like zero-day attacks).
- *Grey Risk*: Partially understood security issues that need more attention to prevent problems (like incomplete patches or misconfigurations).

2. **CIS Benchmark Control Content Categories?**
   - **Profile Applicability:** Defines which systems the control applies to.
   - **Description:** Overview of the security control.
   - **Rationale:** Explains why the control is important.
   - **Audit:** How to check if the control is implemented correctly.
   - **Remediation:** Steps to fix any security gaps.
   - **Impact:** Possible consequences of applying the control.
   - **Default Value:** The system's default configuration.
   - **References:** Related security standards or guidelines.

3. **What are the Cybercrime Laws in Pakistan?**
   - **PECA 2016 (Prevention of Electronic Crimes Act):** Covers cyber offenses such as hacking, identity theft, and online harassment.
   - **Pakistan Telecommunication (Re-Organization) Act 1996:** Regulates electronic communication.
   - **Electronic Transactions Ordinance 2002:** Governs digital signatures and online transactions.
   - **PECB (Prevention of Electronic Crimes Bill) 2015:** Proposed framework for cybersecurity regulations.

4. **IEEE 802.11x Objectives and Ports**
    - **Objectives:**
        - Provides authentication and access control for wireless networks.
        - Implements **EAP (Extensible Authentication Protocol)** for secure authentication.
        - Prevents unauthorized access to WLANs.
        - Uses **RADIUS (Remote Authentication Dial-In User Service)** for centralized authentication.
        - Helps prevent **rogue access points** and unauthorized devices.
    - **Ports Used:**
        - **Port 1812 (RADIUS Authentication)**
        - **Port 1813 (RADIUS Accounting)**
        - **Port 1645/1646 (Legacy RADIUS Ports)**

Short Questions

1. **Parts of a Virus**

   A computer virus typically consists of three main parts:
    - **Infection Mechanism:** Finds and infects new files.
    - **Payload:** The malicious activity performed by the virus.
    - **Trigger:** Determines when the payload will execute.

2. **Nmap Syntax for Given IP Addresses (192.168.3.1, 192.168.3.2, 192.168.3.3)**

- To scan these specific IPs in Nmap, the correct command is:

  ```
  nmap 192.168.3.1 192.168.3.2 192.168.3.3
  ```

- If scanning a range:

  ```
  nmap 192.168.3.1-3
  ```

- If scanning an entire subnet:

  ```
  nmap 192.168.3.0/24
  ```

3. **Two Modes of IPsec**
   - **Transport Mode:** Encrypts only the data payload of the packet (used in end-to-end communication).
   - **Tunnel Mode:** Encrypts the entire IP packet (used for VPNs).

4. **CIS vs DISA - Comparison Table**
   - **Control Coverage:** CIS (Good), DISA (Excellent)
   - **Organization Suitability:** CIS (Small & Medium Organizations), DISA (Large Organizations)
   - **User-Friendliness:** CIS (Good), DISA (Satisfactory)
   - **Industry Credibility:** CIS (High), DISA (Very High)
   - **Tools Used:** CIS (CIS-CAT), DISA (SCAP/STIG Viewer)

5. **Three Security Risks of Wireless LAN Compared to Wired LAN**
   - **Eavesdropping:** Wireless signals can be intercepted by attackers.

- **Unauthorized Access:** Open or weakly protected Wi-Fi networks allow attackers to join the network.
- **Denial of Service (DoS) Attacks:** Attackers can flood the network with traffic to disrupt communication.

Long Questions

1. **Five Cybercrime Laws in Pakistan**
   - **PECA 2016 (Prevention of Electronic Crimes Act):** Covers hacking, data breaches, and identity theft.
   - **Electronic Transactions Ordinance 2002:** Governs digital contracts and electronic signatures.
   - **Pakistan Telecommunication (Re-Organization) Act 1996:** Regulates telecommunication and cybersecurity policies.
   - **Cyber Terrorism Law (Under PECA):** Criminalizes cyber-terrorism and illegal online activities.
   - **Data Protection Bill (Proposed):** Aims to regulate personal data protection in Pakistan.

2. **Linux Syntax for "Togarate...txt" and Nmap Scan Command**
   - To create a file in Linux:

     ```
     touch togarate.txt
     ```

- To scan this file using Nmap (if referring to scanning a host with the name "togarate.txt" or checking an IP from a file):

  ```
  nmap -iL togarate.txt
  ```

- If scanning a host named "togarate":

  ```
  nmap togarate
  ```

- If checking the open ports of a system:

  ```
  nmap -p- <IP-ADDRESS>
  ```

3. **IEEE 802.1x Activities**
   - **Authentication:** Uses EAP (Extensible Authentication Protocol) for verifying devices.
   - **Authorization:** Grants network access to authenticated users.
   - **Accounting:** Logs network activity for security monitoring.
   - **Port-Based Network Access Control:** Prevents unauthorized devices from accessing LAN/WLAN.
   - **Integration with RADIUS:** Uses RADIUS for centralized authentication and user management.

4. **Hiding Techniques Challenges in Forensic Security + Real Implemented Examples**

   Challenges in Forensic Security:

- **Encryption:** Attackers use encryption to hide files and communications.
- **Steganography:** Malicious data can be hidden inside images or videos.
- **Obfuscation:** Malware uses obfuscation techniques to evade detection.
- **Fileless Malware:** Runs directly in memory without leaving a trace on disk.

Real Implemented Examples:

- **Steganography:** Terrorist groups hiding messages inside image files.
- **Encryption:** Ransomware encrypting user files to demand ransom.
- **Obfuscation:** Malware modifying its code to avoid antivirus detection.
- **Rootkits:** Advanced persistent threats (APTs) using rootkits to maintain access to compromised systems.

Short Questions

1. **Which security standard is used for card transactions?**
   - **PCI DSS (Payment Card Industry Data Security Standard)** ensures that all systems that **accept, process, store, or transmit credit card information** maintain a secure environment.

2. **Name the two uncertain port states in Nmap?**

- **Open | Filtered** → The port is either open or filtered, but Nmap cannot determine which one.
- **Closed | Filtered** → The port is either closed or filtered, but Nmap cannot determine the exact state.

3. **Which IEEE standard is used for wired and wireless networks?**
   - **Wired LAN: IEEE 802.3** (Ethernet Standard)
   - **Wireless LAN: IEEE 802.11** (Wi-Fi Standard)

4. **What is a Trojan Horse?**
   - A **Trojan Horse** is a type of **malware** that disguises itself as legitimate software but secretly performs malicious actions, such as stealing data or providing unauthorized access to hackers.

5. **Conceptual Question from Security Hardening (Week 14)**
   - **Security Hardening** is the process of **securing systems** by reducing vulnerabilities.
   - **Examples of security hardening:**
     - **Disabling unnecessary services and ports**
     - **Applying regular security patches**
     - **Using firewalls and intrusion detection systems (IDS)**
     - **Enforcing strong authentication mechanisms**

By Maha Rana

Long Questions

1. **Steps to Implement HTTPS**
    - **Step 1: Obtain an SSL/TLS Certificate** (from a Certificate Authority like Let's Encrypt, DigiCert).
    - **Step 2: Install the Certificate on the Web Server.**
    - **Step 3: Configure the Web Server to use HTTPS.**
    - **Step 4: Redirect HTTP to HTTPS** (using .htaccess or server settings).
    - **Step 5: Enforce HTTPS Security Policies** (HSTS, CSP, and secure cookies).

2. **What is Shell Code?**
    - **Shellcode** is a small piece of malicious code used in **buffer overflow attacks** to gain **unauthorized access** to a system.
    - **Purpose:** It is injected into a vulnerable process to execute commands, often leading to remote code execution (RCE).
    - **Example:** Attackers use **NOP sleds** and exploit stack overflows to insert shellcode and gain control of a system.

3. **CIS Security Benchmark Content - Any 5**
    - **Profile Applicability** (Which systems the control applies to).
    - **Description** (Overview of the control).
    - **Rationale** (Why the control is needed).
    - **Audit** (Steps to verify control implementation).

- **Remediation** (How to fix non-compliance issues).

Short Questions

1. **Define Trojan Horse**
   - A **Trojan Horse** is a type of **malware** that appears to be a legitimate software but actually performs malicious actions, such as stealing data, creating backdoors, or spying on users.
2. **Nmap Command to Scan Three IP Addresses at Once**
   - To scan **multiple IPs simultaneously**, the correct command is:

     ```
     nmap -p- 192.168.1.1 192.168.1.2 192.168.1.3
     ```

   - **Explanation:**
     - **`-p-`** → Scans **all** 65,535 ports of the given IPs.
     - **Multiple IPs can be listed one after another.**

3. **Purpose of SSL (Secure Sockets Layer)**
   - SSL is used to **encrypt communication** between a user and a website to ensure **data confidentiality, integrity, and authentication**.
   - **Key Functions:**
     - Encrypts **sensitive information** (e.g., passwords, credit card details).
     - Prevents **man-in-the-middle (MITM) attacks**.
     - Ensures the **authenticity** of a website (via SSL certificates).

4. **Three Types of Phishing Attacks**
    - **Spear Phishing:** A targeted attack on specific individuals or organizations.
    - **Whaling:** Aimed at high-profile executives (CEOs, CFOs).
    - **Smishing:** Phishing attacks carried out via SMS messages.

    - **CIS CAT Question**
    - Likely related to **CIS-CAT (CIS Configuration Assessment Tool)**, which **automates security compliance assessments**.
    - Possible topics:
        - **Automated security scanning.**
        - **Generating compliance reports.**
        - **Benchmarking against CIS standards.**

5. **Purpose of 'Coordinates' in Wireless LAN**
    - **Coordination Function in WLAN** manages how multiple devices share the wireless medium to **avoid collisions**.
    - **Two Types of Coordination in IEEE 802.11:**
        - **DCF (Distributed Coordination Function):** Uses CSMA/CA (Carrier Sense Multiple Access with Collision Avoidance).
        - **PCF (Point Coordination Function):** Uses polling for better control in infrastructure networks.

By Maha Rana

Long Questions

1. **Five Phases of IEEE 802.11i Operation**
    - **Phase 1: Discovery** – Wireless client identifies available access points.
    - **Phase 2: Authentication** – The client and access point verify identities using 802.1X/EAP.
    - **Phase 3: Key Management** – Secure keys are exchanged for encryption (e.g., 4-way handshake).
    - **Phase 4: Protected Data Transfer** – Data is encrypted using WPA2 (AES-CCMP or TKIP).
    - **Phase 5: Connection Termination** – When the session ends, encryption keys are destroyed.

2. **What is Defensive Method? How does it differ from Traditional Methods? Purpose?**
    - **Defensive Method:** A proactive cybersecurity strategy that **identifies, detects, and mitigates** attacks **before they cause damage**.
    - **Difference from Traditional Methods:**

Defensive Security	Traditional Security
Focuses on **preventing** attacks	Focuses on **reacting** after attacks
Uses **AI, automation, and threat intelligence**	Uses **firewalls, antivirus, and manual monitoring**
More **adaptive and predictive**	More **static and rule-based**

- **Purpose of Defensive Methods:**
  - Reduce attack surfaces.
  - Improve real-time threat detection.
  - Automate security responses.

2. **How Criminals Use Phishing Techniques? (Write Any 5)**
   - **Email Spoofing:** Sending fake emails pretending to be a trusted source (e.g., banks).
   - **Fake Websites:** Creating **clone websites** that look identical to legitimate ones.
   - **Social Engineering:** Manipulating victims into providing personal information.
   - **Credential Harvesting:** Stealing login credentials through fake login pages.
   - **Malicious Attachments:** Sending infected documents that install malware.

Short Questions

1. **Nmap Command**
   - **Basic Scan of an IP Address:**

- Basic Scan of an IP Address:

```
bash

nmap 192.168.1.1
```

- Scan Multiple IPs:

```
bash

nmap 192.168.1.1 192.168.1.2 192.168.1.3
```

By Maha Rana

- Scan All Ports of an IP Address:

```bash
nmap -p- 192.168.1.1
```

- Aggressive Scan (OS, version detection, script scanning, traceroute):

```bash
nmap -A 192.168.1.1
```

1. **Security Standards**
    - **ISO 27001:** Information Security Management System (ISMS).
    - **PCI DSS:** Payment Card Industry Data Security Standard (protects cardholder data).
    - **NIST Cybersecurity Framework:** Risk management framework for cybersecurity.
    - **CIS Benchmarks:** Security best practices for various platforms.
    - **HIPAA:** Protects healthcare data privacy and security.

2. **IEEE 802.11 Operations (Phases of Operation)**
    - **Discovery:** Wireless client detects available access points.
    - **Authentication:** The client and AP verify each other.
    - **Key Management:** Secure key exchange for encryption.
    - **Protected Data Transfer:** Encrypted communication using WPA2/WPA3.
    - **Connection Termination:** Ends session and clears security keys.
3. **Software Errors**

- **Syntax Errors:** Mistakes in code structure (e.g., missing semicolons).
- **Logical Errors:** Code runs but produces incorrect output.
- **Runtime Errors:** Errors that occur during program execution (e.g., division by zero).
- **Buffer Overflow Errors:** When a program writes more data to a buffer than its allocated memory.
- **Memory Leaks:** When allocated memory is not freed, causing excessive resource use.

4. **Cyber Security Laws in Pakistan**
   - **PECA 2016 (Prevention of Electronic Crimes Act):** Covers hacking, identity theft, cyberstalking, etc.
   - **Electronic Transactions Ordinance 2002:** Governs digital signatures and e-commerce security.
   - **Pakistan Telecommunication (Re-Organization) Act 1996:** Regulates cybersecurity in telecom.
   - **Cyber Terrorism Law (Under PECA 2016):** Criminalizes cyber-terrorist activities.
   - **Data Protection Bill (Proposed):** Focuses on data privacy and security measures.

1) Nmap Flags (Important Flags & Their Uses)

Flags (options) modify the behavior of Nmap scans. Some commonly used ones include:

By Maha Rana

Flag	Use	Example
`-p`	Specify a port or range	`nmap -p 80 192.168.1.1`
`-p-`	Scan **all** 65,535 ports	`nmap -p- 192.168.1.1`
`-A`	**Aggressive scan** (OS, versions, scripts, traceroute)	`nmap -A 192.168.1.1`
`-sS`	**Stealth Scan** (SYN Scan)	`nmap -sS 192.168.1.1`
`-sV`	**Service Version Detection**	`nmap -sV 192.168.1.1`
`-O`	**Detect OS of the target**	`nmap -O 192.168.1.1`
`-Pn`	**Disable ping check (scan even if host appears down)**	`nmap -Pn 192.168.1.1`
`-F`	**Fast scan (top 100 ports only)**	`nmap -F 192.168.1.1`

2) Famous Hackers & Attackers

Some well-known cyber attackers and hackers in history:

1. **Kevin Mitnick** – Social engineering expert, hacked into government and corporate systems.
2. **Anonymous** – Decentralized hacking group known for DDoS attacks.
3. **Edward Snowden** – Former NSA contractor who leaked classified surveillance data.
4. **Adrian Lamo** – Hacker who reported Chelsea Manning's leaks.
5. **Gary McKinnon** – British hacker who broke into NASA and Pentagon systems.

---

3) Five Cyber Crimes in Pakistan (Current Situation)

By Maha Rana

Under **PECA 2016 (Prevention of Electronic Crimes Act)**, the following cyber crimes are punishable in Pakistan:

1. **Cyber Terrorism** – Use of digital means to spread fear, attack critical infrastructure.
2. **Cyberstalking & Harassment** – Online threats, blackmailing, or defaming individuals.
3. **Financial Fraud & Identity Theft** – Credit card fraud, online scams, fake accounts.
4. **Unauthorized Access (Hacking)** – Gaining illegal access to government or private systems.
5. **Spreading Misinformation & Hate Speech** – Fake news, religious/political hate content online.

 Pakistan's situation: Cybercrime cases are rising due to increased **social media misuse, hacking attempts, financial frauds**, and **online harassment cases**. FIA Cybercrime Wing is responsible for handling these cases.

---

4) Buffer Overflow (Concept & Explanation)

- **What is Buffer Overflow?**
  - A **security vulnerability** where a program writes **more data** to a memory buffer than it can hold, **overwriting adjacent memory**.
  - Attackers exploit buffer overflows to **execute arbitrary code** or **crash the system**.
- **Example Attack Process:**
  1. **Find a vulnerable program** (e.g., old C applications).

2. **Input oversized data** (longer than expected).
3. **Overwrite return addresses** to execute malicious shellcode.
4. **Gain unauthorized access or crash the system.**

- **Mitigation Techniques:**

  ✅**DEP (Data Execution Prevention)** – Prevents execution of injected code.

  ✅**ASLR (Address Space Layout Randomization)** – Randomizes memory locations.

  ✅**Stack Canaries** – Inserts security values in memory to detect overflow.

---

1) Nmap-Related

Nmap is used for **network scanning, vulnerability detection, and security auditing**.

- **Basic Nmap Scan:**

- Basic Nmap Scan:

```bash
nmap 192.168.1.1
```

- Scan Multiple IPs:

```bash
nmap 192.168.1.1 192.168.1.2 192.168.1.3
```

- Full Port Scan:

```bash
nmap -p- 192.168.1.1
```

By Maha Rana

- **Aggressive Scan:**

```
bash

nmap -A 192.168.1.1
```

- **Detect OS & Services:**

```
bash

nmap -O -sV 192.168.1.1
```

---

2) Zenmap Profiles

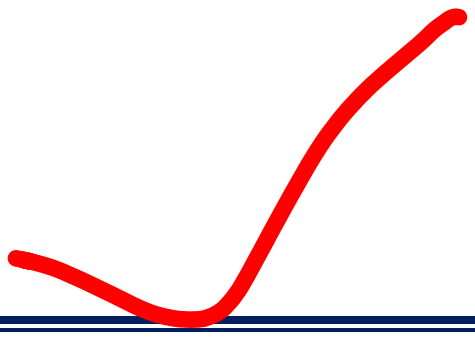
Zenmap is the **GUI version of Nmap**, used for network scanning.

□ Zenmap Scan Profiles:

Profile	Description
Intense Scan	Scans all ports + OS & service detection
Regular Scan	Basic Nmap scan
Quick Scan	Faster scan using a limited number of packets
Quick Scan Plus	Fast scan with version detection
Quick Traceroute	Identifies network routes
Slow Comprehensive Scan	Deep scan with aggressive options

3) Buffer Vulnerability

- **What is Buffer Overflow?**



  - Happens when **more data is written to a memory buffer** than it can hold, causing memory corruption.
  - Attackers use it to **overwrite memory addresses** and execute malicious code.

- **Types of Buffer Overflow Attacks:**

  ✅**Stack Overflow:** Overflows function stack memory.

  ✅**Heap Overflow:** Corrupts dynamically allocated memory.

  ✅**Return-Oriented Programming (ROP):** Chains small code segments to execute arbitrary commands.

- **Prevention Techniques:**

  ASLR (Address Space Layout Randomization)

  DEP (Data Execution Prevention)

  Stack Canaries

---

4) SSH & SSL

SSH (Secure Shell)

- Used for **secure remote login and command execution**.
- Provides **encryption, authentication, and integrity**.
- Ports: **22 (default)**

SSL (Secure Sockets Layer)

- Encrypts **web communications** between browser and server.
- Uses **HTTPS (port 443)** to protect **user credentials, transactions, and sensitive data**.

By Maha Rana

□ Key Difference Between SSH & SSL

Feature	SSH	SSL
Purpose	Secure remote access	Secure web traffic
Protocol	Used in shell commands	Used in HTTPS
Ports	22	443
Encryption	RSA, AES	TLS, SSL

5) OS Security

- **Security Layers in OS:**

  ✓**Authentication** – Verifies user identity.

  ✓**Authorization** – Controls access to system resources.

  ✓**Integrity Checks** – Ensures system files are not altered.

  ✓**Patch Management** – Regular OS updates to fix security flaws.
- **Common OS Attacks:**
  - Privilege Escalation
  - Rootkits
  - Kernel Exploits

6) Cyber Crimes

□ Types of Cyber Crimes:

By Maha Rana

Type	Example
Hacking	Unauthorized system access
Identity Theft	Using stolen credentials for fraud
Phishing	Fake emails to steal sensitive data
Cyberstalking	Online harassment
DDoS Attacks	Overloading servers to crash websites

7) Malware Types

- **Virus:** Self-replicating malware that **attaches to files**.
- **Worm:** Spreads **without user interaction**.
- **Trojan Horse:** Disguised as legitimate software.
- **Spyware:** Monitors user activity.
- **Ransomware:** Encrypts files and demands ransom.

---

8) Difference Between Computer Forensics & Network Forensics (Long Question)

Aspect	Computer Forensics	Network Forensics
Focus	Investigates files, disks, and OS logs	Analyzes network traffic, packets, and logs
Data Source	Hard drives, RAM, registry	Firewalls, routers, Wireshark captures
Purpose	Recover deleted data, analyze malware	Detect intrusions, track cybercriminals
Example Tools	FTK, EnCase, Autopsy	Wireshark, Snort, Suricata

1) Nmap Default Ports (Short Question)

By Maha Rana

- By default, **Nmap scans the 1,000 most commonly used TCP ports** on a target system.
- **Full port scan (all 65,535 ports):**

```
nmap -p- 192.168.1.1
```

- **Commonly scanned ports include:**
  - **80 (HTTP)**
  - **443 (HTTPS)**
  - **22 (SSH)**
  - **53 (DNS)**
  - **25 (SMTP)**
  - **3389 (RDP)**

---

2) Trojan Horse (Short Question)

- **Definition:** A **Trojan Horse** is a type of malware that **disguises itself as legitimate software** but secretly performs malicious activities, such as:
  - Stealing data
  - Creating backdoors
  - Logging keystrokes
- **Example:** Fake antivirus software that tricks users into installing malware.

---

3) Phishing Techniques (Short Question)

- **Spear Phishing:** Targeted phishing attack on a specific person/organization.

- **Whaling:** Phishing attack targeting high-profile individuals like CEOs.
- **Smishing:** Phishing attack conducted through SMS messages.
- **Vishing:** Voice phishing using phone calls to extract sensitive information.
- **Clone Phishing:** Duplicate emails that look like real ones but contain malicious links.

---

4) Demerits of ISO 27001:2013 (Short Question)

- **Broad & Generalized:** Does not specify detailed implementation steps.
- **Costly & Resource-Intensive:** Requires dedicated teams for compliance.
- **Time-Consuming:** Full implementation takes **months to years**.
- **Not Industry-Specific:** Lacks specific controls for certain industries.
- **Complex Certification Process:** Involves regular audits and documentation.

---

5) SSL Handshake Steps (Short Question)

 SSL Handshake Process (Between Client & Server):

1. **Client Hello:** Client sends a request with supported encryption algorithms.
2. **Server Hello:** Server responds with chosen encryption method.
3. **Certificate Exchange:** Server sends its SSL certificate.
4. **Key Exchange:** Client generates a **session key** and encrypts it.
5. **Finished Message:** Secure connection is established.

 Post-Handshake:

✅All data is now **encrypted** using the shared session key!

---

6) ISO 27001:2013 Contents (4-Way Handshake & Security Controls)

 Key Sections in ISO 27001:

1. **Information Security Policies** – Guidelines for data protection.
2. **Risk Assessment & Treatment** – Identifies and mitigates threats.
3. **Access Control** – Restricts unauthorized access to systems.
4. **Cryptography** – Encrypts sensitive data for security.
5. **Network Security** – Secures networks from intrusions.
6. **4-Way Handshake (Wireless Security - IEEE 802.11i):**
    - Step 1: Client & AP exchange keys.
    - Step 2: Generate Pairwise Master Key (PMK).
    - Step 3: Secure data encryption setup.
    - Step 4: Confirm & finalize connection.

---

7) Data Hiding Techniques & Real-World Examples (Short Question)

 Techniques:

- **Steganography:** Hiding data inside images, videos, or audio files.
    - **Example:** Criminals use image files to secretly send messages.
- **Encryption:** Converts data into unreadable form.
    - **Example:** WhatsApp end-to-end encryption protects chats.

- **Obfuscation:** Making source code unreadable to avoid detection.
    - **Example:** Malware uses obfuscation to evade antivirus programs.
- **Covert Channels:** Uses non-traditional methods to transmit data.
    - **Example:** Hiding data inside network packets.

---

8) DISA STIG (Security Technical Implementation Guide) - Five Content Names

Five Key Components of DISA STIGs:

1. **General Information:** Basic details about security controls.
2. **Check Content:** Step-by-step verification of compliance.
3. **Fix Text:** Guidelines to correct security issues.
4. **Severity Levels (CAT I, II, III):** Defines the risk level of vulnerabilities.
5. **Control Correlation Identifier (CCI):** Maps security controls to industry standards.

----------THE END----------

By Maha Rana

May Allah grant you success, ease your efforts, and bless you with wisdom and perseverance. Keep your faith strong, for with prayer, every challenge becomes an opportunity. I hope this file helps you a lot, and please remember me in your prayers.

Best wishes for Finals!
Maha ☺